



DEVELOPMENT TEAM PROJECT: RISK IDENTIFICATION REPORT

Sultan Alkaabi & Victor Angelo & Leeann Leong

1. Risk Assessment of the Current Business

1.a Methodology Selection and Justification

A **hybrid qualitative–semi-quantitative risk-assessment methodology** was adopted, following the principles of **ISO 31000:2018** and **NIST SP 800-30 Rev. 1**.

- **Justification:** Pampered Pets lacks detailed incident data, making a **qualitative** approach more practical. The addition of a simple 1–5 scale for *likelihood* × *impact* (semi-quantitative scoring) enables clear prioritisation.
- **Support from literature:** AuditBoard (2025) and Drata (2024) highlight that hybrid methods provide the best balance of clarity and accuracy for small organisations, while ISACA (2021) recommends their use when quantitative data are limited.

Under this approach, each asset was assessed for potential threats, vulnerabilities, and controls. Risk = Likelihood × Impact (L×I) on a 1–5.

1.b Threat and Risk Modelling

Asset / Process	Threat	Vulnerability	Likelihood	Impact	Existing Controls	Gaps / Notes
Sales system (front-desk PC + Wi-Fi)	Malware or ransomware causing downtime	Outdated security and shared network	3	4	None	No antivirus, no segmentation, no backups
Warehouse PC (legacy)	Data corruption / hardware failure	Old, unpatched system	2	3	Spreadsheet tracking	No data redundancy
Wireless network	Unauthorised access / data breach	Weak password, shared with smartphones	3	3	None	No guest network, unknown encryption
Local supply chain	Supplier disruption	Reliance on few local farms	2	4	Strong supplier trust	No backup suppliers
VAT/Tax data	Data loss / inaccuracy	No off-site backup or audit trail	2	5	Digital records	No integrity checks
Product quality	Contamination / poor ingredients	Manual quality checks only	2	5	Local sourcing	No HACCP system
Premises	Fire, theft, or flood	No continuity or insurance evidence	1	5	Physical security	No BCP/DRP

Key findings:

The highest-scoring risks are (1) malware infection (12), (2) tax/financial data loss (10),

and (3) product contamination (10). These pose the most immediate operational and reputational threats.

2.c Mitigations for Current Risks

Risk	Proposed Mitigation
Malware / ransomware	Contract security services from a reputable MSSP to implement and manage the necessary security and data controls.
Legacy hardware	Migrate to the cloud to modernize hardware and software, reducing the maintenance cost.
Wi-Fi security	Configure WPA3 encryption, use network access control to separate staff from guests, and change default credentials.
Supply chain	Identify alternative suppliers, maintain a buffer stock, and document sourcing contracts.
VAT / data integrity	Create off-site backups, validate records quarterly, and maintain audit trails for VAT submissions.
Product quality	Implement HACCP-based controls; maintain ingredient traceability logs; and conduct regular internal audits.
Premises continuity	Develop Business Continuity Plan (BCP); verify insurance; store digital backups off-site.

Overall mitigation summary:

- Maintain a formal risk register and re-assess annually under the ISO 31000 “Plan–Do–Check–Act” cycle.
- Provide staff training on cybersecurity and emergency procedures.
- Once baseline controls are in place, reassess readiness for digital expansion.

3. Risk Assessment of the Proposed Digitalisation / Transformation

3.a Methodology and Justification

The same **ISO 31000/NIST SP 800-30 hybrid model** was used for comparability.

- Ensures continuity between current-state and future-state assessments.
- Appropriate for SMEs lacking quantitative risk data.
- Provides a holistic view combining cyber, operational, and supply-chain perspectives.
- Frameworks are internationally recognised and scalable for future growth.

3.b Proposed Digital Changes

1. **E-commerce website** – Enable online ordering, delivery, and click-&-collect.
2. **ERP / inventory system** – Integrate warehouse, sales, and suppliers.
3. **International supply chain** – Import lower-cost ingredients (~24 % savings target).
4. **Online marketing** – SEO, social media, and digital campaigns.
5. **Cloud data storage & backup** – Centralised, secure data access.

These initiatives promise growth and efficiency, but they also introduce cybersecurity, legal compliance, and change-management risks.

3.c Threat and Risk Modelling

Asset / Process	Threat	Vulnerability	Likelihood	Impact
E-commerce website	Data breach (customer / payment data)	Insufficient security controls	4	5
Hosting / website uptime	DDoS attack or outage	Single hosting provider	3	4
ERP system	Integration failure / data corruption	Limited technical skills	3	4
Cloud infrastructure	Ransomware / credential theft	Weak access controls	4	5
International suppliers	Supply disruption / poor quality	Long lead times, variable standards	3	4
Currency payments	FX volatility / fraud	Unsecured payment routes	3	3
Staff training	Misuse of systems	Lack of training	3	3
Legal compliance	GDPR / import-export violations	Inexperience with regulations	2	4
Reputation	Negative reviews / poor UX	Weak online customer support	3	4

Analysis:

Critical risks (≥ 15) = Cyber-attack & ransomware (20).

High risks (12) = Website downtime, ERP errors, supply chain, and reputation.

Moderate risks (8–9) = Staff training, compliance, currency.

Digitalisation offers significant growth potential (≈ 50 % increase) but considerably enlarges the cyber-attack surface.

3.d Mitigations for Digitalisation Risks

Risk	Mitigation Measures
Data breach / cyber-attack	Implement TLS encryption, MFA, and PCI-DSS-compliant payment gateway; regular penetration testing; GDPR policy and training.
Website downtime	Use reliable hosting with 99.9 % SLA; enable DDoS protection (e.g., Cloudflare); maintain daily backups and monitoring.
ERP integration issues	Pilot testing in sandbox environment; staff training; data validation; rollback plan.
Cloud ransomware / breach	Enforce least-privilege access, MFA, encrypted backups, and cyber-insurance; establish incident response plan.
Supply-chain disruption	Vet suppliers with ISO 9001 / HACCP certification; dual sourcing; buffer stock; SLAs.
Currency / fraud	Use trusted payment platforms; dual-approval for transactions; FX hedging.
Staff readiness	Deliver digital skills training, appoint a “digital champion,” and implement a phased rollout.
Legal / compliance	Consult e-commerce and trade law specialist; register with ICO; maintain records for VAT and GDPR.
Reputation / UX	Design a user-friendly website; implement responsive customer support; monitor online reviews.

General controls:

- Maintain a digital risk register (review quarterly).
- Apply ISO 27001 controls gradually (access, asset management, incident response).
- Create Business Continuity and Disaster Recovery plans for digital assets.
- Review residual risk post-implementation for continuous improvement.

References: ISO 27001 (2022); NCSC (2024) *10 Steps to Cyber Security*; Gartner (2024) *Best Practices for SME Cyber Resilience*.

4. Recommendation

Pampered Pets **should proceed with digitalisation**, provided all key mitigations are applied before rollout. This digitalization process has the potential to increase growth in microbusinesses by 14.8% to 50%, based on numerous studies (GOV.UK Digital Adoption Report, 2024; Nagarajan, 2025; Epos Now, 2022). Additionally, international expansion by adding international suppliers is known to reduce costs, but it will depend on the product needed. For instance, importing cereals from Ukraine or other countries will have the same or a higher price than buying from local farms (AHDB, 2022). But lamb and other meat prices can be up to a quarter of the price of meat sourced locally (AHDB, 2025).

The transformation should be delivered in four phases:

1. **Phase 1 – Stabilisation:** Upgrade hardware, secure Wi-Fi, and establish backup systems.
2. **Phase 2 – E-Commerce Launch:** Build a secure website with click-&-collect and online payments; staff training.
3. **Phase 3 – ERP Integration:** Introduce inventory and sales integration; monitor accuracy and errors.
4. **Phase 4 – International Expansion:** Pilot foreign suppliers with due diligence and quality checks; retain local backup suppliers.

Throughout, the business should regularly monitor its risk register, review controls quarterly, and consider purchasing cyber-insurance for enhanced financial resilience.

If digitalisation is delayed, Pampered Pets risks losing ≈33 % of customers to online competitors and missing growth opportunities (Statista, 2025; GOV.UK Digital Adoption Report, 2024).

5. Conclusion

This report evaluated Pampered Pets' existing risks and those arising from digital transformation.

While digitalisation introduces cyber, legal, and operational challenges, these can be mitigated through strong controls, governance, and training.

Adopting the ISO 31000/NIST hybrid framework ensures a structured and repeatable risk management process (Hyperproof, 2024).

With phased implementation and continuous monitoring, Pampered Pets can leverage its quality reputation and local roots to achieve sustainable growth, cost savings, and long-term resilience.

References

- Epos Now. (2022) *How much does a website increase sales?* Available at: <https://www.eposnow.com/us/resources/how-much-does-a-website-increase-sales-for-your-business/> (Accessed: 10 November 2025).
- Nagarajan A. (2025). *Digital Can Boost MSME, Manufacturing – EY India News & Insights*. Available at: https://www.ey.com/en_in/insights/technology/how-can-manufacturing-and-msme-s-grow-faster-with-digital-transformation (Accessed: 10 November 2025).

- AuditBoard (2025). *Keys to Developing an Effective Risk Assessment Methodology*. Available at: <https://auditboard.com/blog/risk-assessment-methodology> (Accessed: 10 November 2025).
- Drata (2024). *6 Types of Risk Assessment Methodologies and How to Choose One*. Available at: <https://drata.com/grc-central/risk/risk-assessment-methodologies> (Accessed: 10 November 2025).
- ISACA (2021). *Risk Assessment and Analysis Methods* Available at: <https://www.isaca.org/resources/isaca-journal/issues/2021/volume-2/risk-assessment-and-analysis-methods> (Accessed: 10 November 2025).
- NCSC (2024). *A Basic Risk Assessment and Management Method & 10 Steps to Cyber Security*. Available at: <https://www.ncsc.gov.uk/collection/risk-management> (Accessed: 10 November 2025).
- ISO 31000:2018. *Risk Management – Guidelines*. International Organization for Standardization.
- ISO 27001:2022. *Information Security Management Systems – Requirements*.
- Gartner (2024). *Best Practices for SME Cyber Resilience in Digital Transformation*.
- Hyperproof (2024). *IT Risk Assessment and Continuous Monitoring*.
- GOV.UK (2024). *SME Digital Adoption and E-Commerce Study*.
- Statista (2025). *UK E-Commerce Market Overview*.
- AHDB, (2022). *UK import parities*. Available at: <https://ahdb.org.uk/uk-import-parities> (Accessed: 10 November 2025).
- AHDB, (2025). *Global cattle prices*. Available at: <https://ahdb.org.uk/uk-import-parities> (Accessed: 10 November 2025).

Appendices

Appendix 1 – Risk Quantification

Level	Likelihood (Probability of Occurrence)	Impact (Severity of Consequence)
1	Rare: Expected to occur once every 10 years or less.	Insignificant: Minimal damage, business operations continue without significant disruption.
2	Unlikely: Expected to occur once every 5 to 10 years.	Minor: Limited damage, business can function with minor disruption or limited production. Recovery within days.
3	Moderate: Expected to occur once every 3 to 5 years.	Moderate: Significant damage, business operations impaired, recovery may take weeks to a few months.
4	Likely: Expected to occur once or more every year.	Major: Severe damage, significant business interruption, recovery may take up to a year or more.
5	Frequent: Expected to occur more than once every year.	Catastrophic: Critical damage, potential for indefinite business cessation or long-term severe disruption.

Appendix 2 – Asset Register

Asset Name	Criticality Level	Justification / Notes
Staff	High	Core to day-to-day operations and customer relationships; loss or absence directly affects service quality.
Offices / Shop Premises	Critical	Primary physical point of sale for 90% of business transactions.
Email System	Medium	Used for customer orders and supplier communication; limited but important function.
Old Warehouse Computer	Low	Outdated system for inventory tracking; being phased out .
Front-Desk Computer	Medium	Records all sales and tax transactions; key operational system.
Pet Food Products	High	Primary revenue source and key differentiator for the brand.
Ingredients (Local Supply)	Medium	Important for quality control but can be substituted if supply chain diversifies.
Wireless Gateway / Hub	Medium	Connects all internal devices; potential entry point for cyber threats.
Local Suppliers	High	Essential for maintaining quality and short supply lead times.
Company Vehicles	Medium	Used to collect ingredients and make local deliveries.
Business Reputation	Critical	Core intangible asset driving trust and repeat sales.
Existing Customers	High	Represent a stable revenue base; customer retention vital for profitability.

Summary:

The **most critical assets** are the shop premises, staff, and business reputation — their loss or compromise would immediately halt operations. Medium- and high-criticality assets (front-desk PC, customers, local suppliers) support day-to-day continuity and revenue generation.

Appendix 3 – Threat Modelling Overview

Asset / Process	Threat	Type	Potential Source / Cause	Impact if Realised
Staff	Human error / phishing	Cyber / Human	Lack of training, malicious emails	Data loss or breach
Front-Desk Computer	Malware / ransomware	Cyber	Outdated OS, no antivirus	System downtime, data corruption
Old Warehouse PC	Hardware failure / data loss	Operational	Ageing equipment	Inaccurate stock records
Wireless Network / Hub	Unauthorised access	Cyber	Weak password, no guest segregation	Network compromise
Pet Food Production	Contamination / poor quality	Operational / Reputational	Inadequate quality control	Brand damage, loss of trust
Local Suppliers	Supply disruption	Operational	Farm closure, transport issues	Ingredient shortage, delayed production

VAT / Tax Records	Data loss / error	Compliance / Financial	Incomplete backups	Regulatory penalties
Premises	Fire, theft, or flood	Physical	Environmental event or burglary	Business interruption
Business Reputation	Negative publicity	Reputational	Poor online reviews or data breach	Customer loss
E-commerce Website (Future)	Data breach / cyber-attack	Cyber	Weak authentication or poor coding	GDPR violation, financial loss
ERP System (Future)	Integration failure	Operational / Technical	Insufficient testing	Data inconsistency, downtime
Cloud Storage (Future)	Ransomware or unauthorised access	Cyber	Weak access controls	Data exposure, business interruption
International Suppliers (Future)	Poor quality / delays	Supply Chain	Lack of vetting, customs delays	Customer dissatisfaction
Online Reputation (Future)	Negative feedback or reviews	Reputational	Poor service or UX	Reduced customer retention

Summary:

Threats span **cyber, operational, and physical domains**, reflecting both current and future-state vulnerabilities.

Most critical future threats are **data breaches, ransomware, and supply-chain reliability**, aligning with ISO 31000's principle of context-driven risk identification.